

Security+ 1.2 · Deception & Disruption

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.2** —
Deception & Disruption (4:30) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Deception and disruption techniques lure and study attackers. Honeypots are fake systems that appear real but are monitored. Honeynets are networks of honeypots. Honeyfiles are decoy files with beacons that trigger alerts when opened. DNS sinkholes redirect malicious domains to null IPs and log attempts. False Azure is a service mimicking cloud environments.

High-Yield Core Concepts Tested on Exam

- Honeypot = fake target: looks real, is monitored
- Honeyfile: decoy document with beacon — triggers alert when opened
- DNS sinkhole = redirects C2 traffic to null IP and LOGS the attempt
- Honeynet = network of honeypots
- Deception detects and studies attacker behavior

Exam Tips & Classic Scenarios

- 'Appears vulnerable but is monitored' = honeypot
- 'Redirects malicious domain traffic' = sinkhole
- Honeyfiles are used to detect insider threats or data exfiltration
- DNS sinkhole is a disruption technique that also provides intelligence

Typical Exam Scenario: A company sets up a server that appears vulnerable but is actually monitored to detect and study intrusion attempts. This is an example of a honeypot.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.2 — Deception & Disruption)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Decoy system that pretends to be vulnerable to attract and study attackers:

- A)** Honeypot
- B)** DMZ
- C)** Bastion host
- D)** Jump box

2. In the Zero Trust model, what is the fundamental principle?

- A)** Always trust internal users
- B)** Trust but verify
- C)** Never trust, always verify
- D)** Trust only VPNs

3. Corporate scenario (Deception & Disruption): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Honeypot = fake target: looks real, is monitored'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Honeypot = fake target: looks real, is monitored...

4. Corporate scenario (Deception & Disruption): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Honeyfile: decoy document with beacon — triggers alert when opened'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Honeyfile: decoy document with beacon — triggers alert when opened.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Deception & Disruption): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'DNS sinkhole = sends C2 to null IP and LOGS who attempted'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: DNS sinkhole = sends C2 to null IP and LOGS who attempted...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Deception & Disruption): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'appears vulnerable but is monitored' = honeypot'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'appears vulnerable but is monitored' = honeypot...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Deception & Disruption): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'redirects malicious domain traffic' = sinkhole'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'redirects malicious domain traffic' = sinkhole...
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Deception & Disruption): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Typical scenario: 'company deploys a falsely vulnerable server to detect and study intrusion' → honeypot.'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Typical scenario: 'company deploys a falsely vulnerable server to detect...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Deception & Disruption): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Honeypot = fake target: looks real, is monitored'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Honeypot = fake target: looks real, is monitored...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Deception & Disruption): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.2), an analyst evaluates the following technical requirement: 'Honeyfile: decoy document with beacon — triggers alert when opened'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Honeyfile: decoy document with beacon — triggers alert when opened...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Honeypot.

✓ **Why it is correct:** A honeypot is a decoy system designed to appear vulnerable and attract attackers, with the goal of studying their tactics, techniques, and procedures (TTPs), diverting attention from real systems, and gathering threat intelligence. It can be low-interaction (simulates services) or high-interaction (isolated real system). It is a proactive security and detection control, per SY0-701 objectives 3.2 (security implementation) and 4.8 (monitoring and detection). The question describes exactly a decoy system that pretends to be vulnerable to attract and study attackers, which is the definition of a honeypot.

✗ **Why the others are wrong:**

- *DMZ:* A DMZ (Demilitarized Zone) is a physical or logical subnetwork that sits between the trusted internal network and the untrusted external network (e.g., the Internet). It hosts public services (web, email, DNS) to prevent external attacks from directly reaching the internal network. A DMZ is not a decoy system; it is a network segment designed to expose services in a controlled manner. It does not pretend to be vulnerable nor aims to attract and study attackers. The question asks for a decoy system, not a segmentation architecture.
- *Bastion host:* A bastion host is a heavily protected system exposed to an untrusted network, typically acting as a single entry point for remote administration or as a proxy. It is hardened and monitored, but it is not a decoy; it is a defense point. Its purpose is to be secure, not to appear vulnerable. The question describes a system that pretends to be vulnerable to attract attackers, which is the opposite of a bastion host, which is designed to be as secure as possible.
- *Jump box:* A jump box (or jump server) is an intermediary system used to access and administer devices in a segregated network, such as a DMZ or internal network. It centralizes administrative access, enforces strong authentication, and logs activities. It is not a decoy; it is an access control tool. It does not pretend to be vulnerable nor aims to study attackers. The question asks for a decoy system, not an administrative jump point.

2) C — Never trust, always verify.

✓ **Why it's correct:** The correct answer is 'Never trust, always verify'. The Zero Trust model, as defined by NIST SP 800-207 and covered in CompTIA Security+, is based on the principle that no entity (user, device, or application) is trusted by default, regardless of whether it is inside or outside the corporate network perimeter. Zero Trust architecture requires continuous verification of identity, context, and authorization for every access to resources, using multi-factor authentication (MFA), microsegmentation, least privilege policies, and constant monitoring. The motto 'never trust, always verify' summarizes the paradigm shift: trust is not implicit but granted dynamically based on policies and evidence.

✗ **Why the others are wrong:**

- *Always trust internal users:* This describes the traditional perimeter-based security model, where everything inside the network is assumed trusted. This is the exact opposite of Zero Trust. Implicit trust in internal users is vulnerable to insider threats, lateral movement, and credential compromise. Zero Trust was created to eliminate this assumption, treating internal networks as potentially hostile and requiring verification for all access, regardless of location.
- *Trust but verify:* This is a variation of the traditional conditional trust model but does not represent Zero Trust. The phrase 'trust but verify' suggests that trust is the initial state, and verification is a complement. In Zero Trust, trust is never presumed; verification is the starting point and occurs continuously. The 'trust but verify' approach still maintains an assumption of trust that can be exploited, whereas Zero Trust requires every request to be authenticated and authorized

before any access.

- *Trust only VPNs*: This reduces Zero Trust to a single remote access technology. Traditional VPNs create an encrypted tunnel, and once authenticated, the user often receives broad access to the internal network, violating least privilege and continuous verification. Zero Trust is not limited to VPNs; it involves microsegmentation, strong authentication, granular policies, and continuous monitoring. Trusting only VPNs maintains the perimeter-based trust model, which is insufficient to protect against modern threats and does not meet Zero Trust requirements.

3) D — Implement the corresponding solution: Honeypot = fake target: looks real, is monitored....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Deception & Disruption): Honeypot = fake target: looks real, is monitored. A honeypot is a decoy system designed to attract attackers, appearing as a legitimate target while being isolated and monitored to gather threat intelligence and divert attacks.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: Honeyfile: decoy document with beacon — triggers alert when opened..

✓ **Why it is correct:** Per the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Deception & Disruption): Honeyfile: decoy document with beacon — triggers alert when opened. A honeyfile is a deception control: a decoy file placed where an attacker is likely to find it. When the file is opened or accessed, an embedded beacon or monitoring mechanism fires an alert to the security team, providing early detection of an intruder and enabling incident response. Honeyfiles are part of the broader deception technology family that includes honeypots, honeynets, and honey tokens.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) A — Implement the corresponding solution: DNS sinkhole = sends C2 to null IP and LOGS who attempted....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Deception & Disruption): DNS sinkhole = sends C2 to null IP and LOGS who attempted.

A DNS sinkhole redirects malicious traffic to a controlled server, logging attempts for analysis.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: 'appears vulnerable but is monitored' = honeypot....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Deception & Disruption): 'appears vulnerable but is monitored' = honeypot. A honeypot is a decoy system designed to attract attackers, appearing vulnerable while being closely monitored to detect and analyze attack techniques. It serves as a deception mechanism to divert attention from real assets and gather threat intelligence.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting principle and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: 'redirects malicious domain traffic' = sinkhole....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Deception & Disruption): 'redirects malicious domain traffic' = sinkhole.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

8) A — Implement the corresponding solution: Typical scenario: 'company deploys a falsely vulnerable server to detect....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 1.2 (Deception & Disruption): Typical scenario: 'company deploys a falsely vulnerable server to detect and study intrusion' → honeypot. A honeypot is a decoy system intentionally designed to appear vulnerable, attracting attackers so their tactics, techniques, and procedures (TTPs) can be observed and analyzed without risking production assets.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: Honeypot = fake target: looks real, is monitored....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Deception & Disruption): Honeypot = fake target: looks real, is monitored. This correctly defines a honeypot as a decoy system designed to attract attackers, appearing as a legitimate target while being isolated and monitored to gather threat intelligence.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: Honeyfile: decoy document with beacon — triggers alert when opened....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.2 (Deception & Disruption): Honeyfile: decoy document with beacon — triggers alert when opened. A honeyfile is a decoy file designed to attract attackers; when accessed or opened, it triggers an alert, helping to detect unauthorized access or insider threats.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.